

# HOR-REG-203 — Alineación a los Principios de Resiliencia Operacional del Comité de Basilea (BIS)

---

Banco Horizonte, S.A., Institución de Banca Múltiple

Versión 3.3 · Vigencia desde 2026-01-30 · Clasificación: Uso Interno

Propietario: Dirección de Riesgos No Financieros (RG-RNF) / Enlace de estándares internacionales (RG-BIS)

## 1. Origen del marco

El Comité de Supervisión Bancaria de Basilea (BCBS), con sede en el Banco de Pagos Internacionales (BIS), publicó el 31 de marzo de 2021 los **Principios para la Resiliencia Operacional** (POR). El objetivo declarado es fortalecer la capacidad de los bancos para resistir eventos relacionados con riesgo operacional que podrían provocar fallas operativas significativas o perturbaciones de amplio alcance en los mercados financieros, tales como pandemias, incidentes cibernéticos, fallas tecnológicas o desastres naturales.

Los POR se construyen sobre los **Principios para la Administración Sólida del Riesgo Operacional** (PSMOR), emitidos originalmente en 2011, revisados en 2014 y revisados por segunda vez de forma simultánea a la publicación de los POR. La revisión de los PSMOR puso énfasis en la gestión del cambio y en las tecnologías de la información y comunicación (TIC).

Estos principios no son ley en México. Son estándar internacional. Banco Horizonte los adopta voluntariamente porque anticipan la dirección de la regulación local y porque, en la experiencia de la institución, describen bien lo que falla en la práctica.

## 2. Definiciones clave

**Resiliencia operacional.** Capacidad de un banco para entregar sus operaciones críticas a lo largo de una interrupción. Esta capacidad debe permitirle identificar y protegerse de amenazas y fallas potenciales, así como responder, adaptarse, recuperarse y aprender de eventos disruptivos, de modo que se minimice su impacto sobre la entrega de operaciones críticas.

**Tolerancia a la interrupción (tolerance for disruption).** Nivel de interrupción, proveniente de cualquier tipo de riesgo operacional, que un banco está dispuesto a aceptar ante un rango de escenarios severos pero plausibles. Los POR indican que la tolerancia debe aplicarse a nivel de operación crítica.

**Supuesto de base.** Al considerar su resiliencia operacional, un banco debe asumir que las interrupciones van a ocurrir, y tomar en cuenta su apetito de riesgo general y su tolerancia a la interrupción.

## 3. Los siete principios y su implementación interna

Los principios se organizan en siete categorías. A continuación, cada una con su correspondencia en Banco Horizonte.

### 3.1 Gobierno

*Principio.* El banco debe utilizar su estructura de gobierno existente para establecer, supervisar e implementar un enfoque efectivo de resiliencia operacional que le permita responder y adaptarse, así como recuperarse y aprender, de eventos disruptivos, minimizando su impacto sobre la entrega de operaciones críticas. El papel del Consejo incluye aprobar el enfoque de resiliencia operacional del banco, considerando su apetito de riesgo y su tolerancia a la interrupción de las operaciones críticas.

*Implementación.* El Consejo de Administración aprueba anualmente la declaración de tolerancia a la interrupción. El Comité de Continuidad de Negocio la traduce en RTO y RPO por servicio (documento HOR-OPS-002). El COTEC vigila su cumplimiento mensualmente.

### 3.2 Gestión del riesgo operacional

*Principio.* El banco debe aprovechar sus funciones de gestión de riesgo operacional para identificar vulnerabilidades externas e internas y evaluar sus riesgos.

*Implementación.* Inventario de riesgos y controles por servicio crítico, indicadores clave de riesgo, modelo de tres líneas de defensa y base de datos histórica de eventos de pérdida, incluidas cuasi-pérdidas.

### 3.3 Continuidad de negocio: planeación y pruebas

*Principio.* El banco debe contar con planes de continuidad de negocio y realizar pruebas frente a un rango de escenarios de interrupción severos pero plausibles, evaluando su capacidad para entregar operaciones críticas durante esas interrupciones.

*Implementación.* Calendario semestral de pruebas con escenarios rotativos:

| Escenario                                    | Frecuencia | Última ejecución | Resultado                                                    |
|----------------------------------------------|------------|------------------|--------------------------------------------------------------|
| Pérdida total del CPD primario               | Anual      | Marzo 2026       | Cumplido con observaciones (RTO real 47 min vs. 20 objetivo) |
| Cifrado malicioso de servidores (ransomware) | Anual      | Septiembre 2025  | No cumplido; replanteado el plan de recuperación             |
| Pérdida de proveedor crítico único           | Semestral  | Marzo 2026       | Cumplido                                                     |
| Indisponibilidad del Command Center          | Anual      | Junio 2026       | Cumplido                                                     |
| Ausencia masiva de personal                  | Bienal     | Noviembre 2024   | Cumplido                                                     |
| Corrupción de datos en core                  | Anual      | Septiembre 2026  | En ejecución                                                 |

### 3.4 Mapeo de interconexiones e interdependencias

*Principio.* Una vez identificadas sus operaciones críticas, el banco debe mapear las interconexiones e interdependencias internas y externas necesarias para entregarlas. El mapeo debe tener granularidad suficiente para identificar vulnerabilidades.

*Implementación.* Banco Horizonte mantiene el mapa de dependencias HOR-MAP-001, que para cada operación crítica documenta: personas, procesos, tecnología, instalaciones, datos y terceros. El mapa se revisa semestralmente y después de cada Major Incident. Hallazgo vigente: 3 operaciones críticas dependen de un único proveedor sin alternativa probada.

### 3.5 Gestión de dependencias de terceros

*Principio.* El banco debe gestionar sus dependencias en relaciones con terceros o con entidades intragrupo para la entrega de operaciones críticas.

*Implementación.* Inventario de terceros críticos, evaluación anual de riesgo, cláusulas de nivel de servicio y auditoría, planes de salida probados y obligación contractual de notificación de incidentes en un máximo de 2 horas.

### 3.6 Gestión de incidentes

*Principio.* El banco debe desarrollar e implementar planes de respuesta y recuperación para gestionar incidentes que pudieran interrumpir operaciones críticas, en línea con su apetito de riesgo y su tolerancia a la interrupción.

*Implementación.* Es el vínculo directo con la Política de Gestión de Incidentes (HOR-OPS-004), el Protocolo de Major Incident (HOR-OPS-006) y la biblioteca de runbooks HOR-RBK-1xx.

### 3.7 Resiliencia de TIC, incluida la ciberseguridad

*Principio.* El banco debe asegurar una gestión de TIC resiliente que soporte sus operaciones críticas.

*Implementación.* Arquitectura activo/activo en servicios Tier 0, gestión de vulnerabilidades con SLA por severidad, gestión del ciclo de vida de certificados (control reforzado tras INC-2026-0417), pruebas de penetración anuales y programa de gestión del cambio con evaluación obligatoria de reversibilidad.

## 4. Declaración de tolerancia a la interrupción (extracto, aprobada por el Consejo)

| Operación crítica                        | Tolerancia máxima de interrupción | Punto máximo de pérdida de datos | Escenario de referencia            |
|------------------------------------------|-----------------------------------|----------------------------------|------------------------------------|
| Transferencias interbancarias            | 15 minutos                        | Cero                             | Falla de sitio primario            |
| Autorización de pagos con tarjeta        | 10 minutos                        | Cero                             | Falla del switch                   |
| Acceso a saldos y movimientos            | 30 minutos                        | 5 minutos                        | Degradación de core                |
| Disposición de efectivo (ATM y sucursal) | 60 minutos                        | Cero                             | Falla de red                       |
| Originación de crédito                   | 8 horas                           | 30 minutos                       | Falla de plataforma de originación |
| Reportes regulatorios                    | 1 día hábil                       | Cero                             | Falla del proceso batch            |

La tolerancia se expresa en términos de **impacto en el cliente y en el sistema financiero**, no en términos de disponibilidad de componentes. Un componente puede estar caído sin que se consuma tolerancia, si existe ruta alterna efectiva.

## 5. Relación con otros marcos

| Marco               | Aportación al modelo interno                                                                          |
|---------------------|-------------------------------------------------------------------------------------------------------|
| PSMOR (BCBS)        | Gestión del riesgo operacional, con énfasis reforzado en gestión del cambio y TIC                     |
| BCBS 239            | Principios de agregación de datos de riesgo y reporte; base del modelo de datos de riesgo operacional |
| ITIL 4              | Vocabulario y ciclo de vida de incidentes, problemas y cambios                                        |
| ISO 22301           | Estructura del sistema de gestión de continuidad de negocio                                           |
| ISO/IEC 27001       | Sistema de gestión de seguridad de la información                                                     |
| NIST CSF            | Estructura de funciones para el programa de ciberseguridad                                            |
| CUB y anexos (CNBV) | Obligación legal en México; prevalece sobre cualquier estándar voluntario                             |

## 6. Brechas abiertas frente a los POR

Identificadas en la autoevaluación de enero de 2026:

1. **Tolerancia a la interrupción no probada bajo escenario combinado.** Las pruebas evalúan un escenario a la vez; el marco sugiere escenarios severos pero plausibles, que en la práctica suelen ser combinados.
2. **Mapeo con granularidad insuficiente en la capa de datos.** El mapa identifica sistemas, pero no siempre los flujos de datos específicos que sostienen la operación crítica.

3. **Terceros de cuarto nivel.** No se tiene visibilidad de los subcontratistas de los proveedores críticos.
4. **Aprendizaje post-evento.** El 31% de las acciones correctivas de postmortems de 2025 se cerraron fuera de la fecha comprometida.

Las cuatro brechas tienen responsable asignado y son revisadas trimestralmente por el Comité de Riesgos.